

GUÍA METODOLÓGICA PARA APLICACIÓN Y ANÁLISIS

Encuesta Integral de Ciberseguridad DORA

Versión: 1.0

Fecha: Enero 2026

Ámbito: España - Instituciones Financieras

TABLA DE CONTENIDOS

1. Introducción Metodológica
2. Fase I: Preparación y Diseño Aplicativo
3. Fase II: Administración de la Encuesta
4. Fase III: Análisis Cuantitativo de Datos
5. Fase IV: Análisis Cualitativo Integrado
6. Fase V: Generación de Reportes Ejecutivos
7. Herramientas Técnicas Recomendadas
8. Interpretación de Resultados
9. Derivación de Roadmap de Mejora

INTRODUCCIÓN METODOLÓGICA

1.1 Propósito y Alcance

Esta guía proporciona instrucciones detalladas para:

10. Preparar la encuesta para aplicación en contexto organizacional específico
11. Administrar la encuesta a stakeholders múltiples de manera estructurada
12. Analizar respuestas cuantitativa (estadística) y cualitativamente
13. Interpretar hallazgos en contexto DORA y amenaza actual
14. Derivar roadmaps de remediación priorizados

1.2 Principios Metodológicos Subyacentes

A. Escala Likert Modificada (5 puntos)

Cada pregunta utiliza gradación:

1 —→ 2 —→ 3 —→ 4 —→ 5
Ad-hoc Bás. Part. Form. Opt.

Racional:

- 5 puntos permite distribución suficientemente granular (vs. 3 = simplista)
- Evita "punto neutral" que induce sesgos de indiferencia
- Ordinal (no intervalar): no asumir distancias iguales; usar mediana, no promedio (técnicamente)
- Prácticamente: media aritmética aceptable si N respondentes ≥ 10

B. Multi-Perspectiva

Cada pregunta dirigida a diferentes roles dentro organización (CISO, CRO, Compliance, Board):

- Visiones divergentes = datos ricos
- Dissonancia = brecha comunicación / alineamiento
- Convergencia = validación de respuestas

C. Validez Interna

Las preguntas están mapeadas a requisitos DORA explícitos:

- Pregunta → Artículo DORA → Requisito técnico

FASE I: PREPARACIÓN Y DISEÑO APLICATIVO

2.1 Definición del Cuestionario Administrable

Tamaño recomendado: Encuesta COMPLETA = 128 preguntas (módulos 1-9)

Opción A: Aplicación Exhaustiva (120-150 minutos)

- Todos 9 módulos
- Contexto: auditoría supervisora inminente o auto-evaluación completa
- Audiencia: CISO + equipo central de riesgos

Opción B: Fast-Track DORA Focus (60-75 minutos)

- Módulos 1-5 (Gobernanza, Riesgos, Incidentes, Vulnerabilidades, Terceros)
- Módulo 8 (Capacitación) reducido
- Contexto: evaluación rápida posición actual
- Audiencia: management + CISO

Opción C: Enfoque Terceros (30-40 minutos)

- Solo Módulo 5 (Gestión Terceros) expandido
- Contexto: evaluación vendor management específico
- Audiencia: Compliance, Procurement, Vendor Risk

2.2 Customización por Entidad

Por tamaño de institución:

Tamaño	Módulos Críticos	Tiempo Recomendado	Profundidad
Pequeña (<€100M AUM)	1,2,3,4,8	45 min	Fast-track; simplificado
Mediana (€100M-€1B)	1-8	75 min	Estándar; balanceado
Grande (>€1B)	1-9	120 min	Exhaustivo; detallado
Grupo financiero	1-9 + consolidation	150+ min	Multi-entidad; consolidado

Por modelo operacional:

Modelo	Adaptaciones
Banco retail	Énfasis Módulo 3 (Incidentes); terceros payment processors
Asset Manager	Énfasis Módulo 5 (Terceros custodios); cloud-heavy
Aseguradora	Énfasis Módulo 2 (Riesgos operacionales); policyholder data
Fintechcripto	Énfasis Módulo 4 (Vulnerabilidades); compliance agresivo
Operador pagos	Énfasis Módulo 3 (Incidentes); real-time monitoring

2.3 Preparación de Cuestionario Digital

Recomendación: Formato Google Forms / SurveyMonkey / Qualtrics

Configuración técnica:

- Preguntas randomizadas dentro módulos (reduce sesgos de orden)
- Branching logic: p.ej., "Si respuesta 1.1.2 = 1, skip a sección 2"
- Validación: preguntas requeridas; rango 1-5 obligatorio
- Tiempo: mostrar estimado (p.ej., "Módulo 3 - 8 min")
- Progreso: barra visual (p.ej., "50% completado")
- Opción de guardar/continuar: critical si administración multi-sesión

Metadata recopilada (no preguntado explícitamente):

- Timestamp inicio/fin (detectar rushed responses)
- IP respondente (validar no duplicados)
- Dispositivo (desktop vs mobile; mobile = lower quality típicamente)

2.4 Designación de Respondentes

Composición recomendada del panel:

Rol	Módulos Responsables	Mandatoriedad
CISO / Chief Security Officer	2,3,4,6,7,8	Mandatorio
CRO / Chief Risk Officer	1,2,5,9	Mandatorio
Chief Compliance Officer	1,9 (lead), 2,5	Mandatorio
Chief Technology Officer	2,4,6,7	Altamente recomendado
CFO / Finance	2(FAIR),5	Recomendado
Board Member (Security)	1 (lead), 9	Recomendado
Head of Ops	3,7	Recomendado
Procurement/Vendor Mgmt	5 (lead)	Altamente recomendado

Dinámica de respuesta:

- **Option A (Recomendado):** Sesión conjunta 90 min; CISO facilita; panel discute q&a

- Ventaja: consenso emergente; resolución conflictos in-situ
- Desventaja: may dominate personalidades
- Option B: Respuestas individuales + validación de convergencia post-encuesta
- Ventaja: perspectivas independientes capturadas
- Desventaja: más tiempo análisis; divergencias requieren reconciliación

2.5 Comunicación Pre-Encuesta

Email de invitación (template):

Asunto: Encuesta de Autoevaluación DORA - Ciberseguridad Integral [Institución]

Estimados colegas,

Nos complace compartir la ****Encuesta Integral de Ciberseguridad DORA****, herramienta de diagnóstico para evaluar nuestra posición actual en cumplimiento DORA y resiliencia digital.

****¿Por qué esta encuesta?***

- DORA entró en vigor 17 de enero 2025; supervisores auditorán intensamente Q2-Q3 2025
- Autoevaluación honesta permite identificar gaps antes de auditoría
- Resultados informarán roadmap remediación estratégico

****Requisitos de Participación:****

- Tiempo: 45-120 min (depende de profundidad módulos)
- Deadline: [fecha]
- Formato: Google Form (link)
- Modalidad: Respuestas conjuntas recomendadas para consenso (vs. individuales)

****Importante:****

- No hay respuestas "correctas"; precisión > perfección
- Honestidad crítica; evaluación construida para identificar áreas mejora
- Confidencialidad: resultados solo para circulación ejecutiva + supervisora

Agradeceremos su participación.

[Firma CISO / CRO]

FASE II: ADMINISTRACIÓN DE LA ENCUESTA

3.1 Modalidades de Administración

Modalidad A: Sesión Facilitada Presencial (RECOMENDADA)

Formato:

- Duración: 90-120 minutos
- Participantes: Panel 6-10 personas (CISO, CRO, Compliance, CTO, Finance, Board)
- Facilitador: Externo (auditor/consultor) recomendado para neutralidad
- Dinámica: Preguntas leídas en voz alta; discusión grupo; consenso por mayoría o facilitation

Ventajas:

- Aclaración in-situ de preguntas ambiguas

- Triangulación de perspectivas
- Consenso emergente reduce inconsistencias
- Dinámicas grupo revelan alineamientos (o falta de)

Desventajas:

- Groupthink: personalities dominantes pueden sesgar
- Time-intensive
- Scheduling challenges

Mitigaciones:

- Facilitador experimentado aplica técnicas de elicitación neutral
- Pausa: permitir silent reflection ~30 sec antes respuesta consenso
- Votación anónima si divergencia: paper votes + agregación

Modalidad B: Respuestas Individuales + Facilitación Post

Formato:

- Respondentes completan encuesta individualmente (48-72 horas)
- Luego: sesión 60 min para discusión hallazgos + divergencias

Ventajas:

- Perspectivas independientes capturadas
- Menos presión social
- Permite análisis previo divergencias

Desventajas:

- Más tiempo consumido (individual + sesión)
- Reconciliación post-hoc más compleja

3.2 Gestión de Respuestas Incompletas

Protocolo si <80% respuestas completadas:

15. Day 1 post-deadline: Email recordatorio a no-respondentes
16. Day 3: Call telefónico CISO a retrasados; asistencia ofrecida
17. Day 5: Escalation a CRO si <70% aún
18. Decision: Extender 1 semana vs. proceder con data disponible

Manejo de non-responders:

- Si respuesta imposible: documentar razón (e.g., "rol no aplica")
- Si no completó parcialmente: usar data disponible; marcar como "incomplete"
- Si no participó: documentar ausencia; no imputar

3.3 Control de Calidad en Administración

Red flags a detectar:

Señal	Acción
Respuestas todas "3" (neutral)**	Clarificar pregunta; verificar comprensión
Cambios respuesta entre módulos (p.ej., "5" en 1; "1" en 9)	Explorar inconsistencias lógicas
Tiempo completación <15 min	Verificar seriedad; re-administrar si needed
Respuestas contradictorias (p.ej., "no scanning" + "CVSS implemented")	Detectar auto-report bias; ajustar
Comentarios negativos excesivos	Manage emotions; refocus en propositivo

FASE III: ANÁLISIS CUANTITATIVO DE DATOS

4.1 Ingesta y Limpieza de Datos

Paso 1: Exportación de respuestas

- Formato: CSV desde Google Forms
- Estructura: Columnas = preguntas; Filas = respondentes

Paso 2: Validación

- Rango: todos valores $\in [1, 5]$
- Completitud: >95% respuestas no-null
- Deduplicación: verificar respondentes únicos (IP, timestamps)

Paso 3: Codificación

Si múltiples respondentes (panel):

- Agregación: MEDIANA (ordinales) vs PROMEDIO (simplificar comunicación)
- Recomendación: si $N_{\text{respondentes}} < 5$, usar MEDIANA; si $N \geq 5$, promedio aceptable

Si respondente único (CISO autoevaluación):

- Usar respuesta directa (no agregación needed)

4.2 Cálculo de CMI (Cybersecurity Maturity Index)

CMI a Nivel Pregunta

Cada respuesta ya es puntuación: 1, 2, 3, 4, o 5

CMI a Nivel Módulo

$CMI_{\text{módulo}} = (\sum \text{respuestas módulo} / N \text{ preguntas módulo})$

Rango: 1.0 - 5.0

Ejemplo Módulo 1 (Gobernanza):

- Preguntas: 1.1.1 a 1.2.3 = 6 preguntas
- Respuestas: 4, 3, 4, 5, 3, 4
- $CMI_1 = (4+3+4+5+3+4) / 6 = 23/6 = 3.83$

CMI Ponderado (Integral)

$CMI_{total} = \sum (CMI_{módulo} \times peso_{módulo})$

Pesos sugeridos:

- Módulo 1 (Gobernanza): 15% $\rightarrow CMI_1 \times 0.15$
- Módulo 2 (Gestión Riesgos): 20% $\rightarrow CMI_2 \times 0.20$
- Módulo 3 (Gestión Incidentes): 20% $\rightarrow CMI_3 \times 0.20$
- Módulo 4 (Vulnerabilidades): 15% $\rightarrow CMI_4 \times 0.15$
- Módulo 5 (Terceros): 15% $\rightarrow CMI_5 \times 0.15$
- Módulo 6 (IAM/Criptografía): 10% $\rightarrow CMI_6 \times 0.10$
- Módulo 7 (Resiliencia): 10% $\rightarrow CMI_7 \times 0.10$
- Módulo 8 (Capacitación): 10% $\rightarrow CMI_8 \times 0.10$
- Módulo 9 (Compliance): 5% $\rightarrow CMI_9 \times 0.05$

$$CMI_{total} = (3.83 \times 0.15) + (3.50 \times 0.20) + \dots + (4.0 \times 0.05)$$
$$= 0.57 + 0.70 + \dots + 0.20$$
$$= X.XX \text{ (score 1-5)}$$

Ajuste de pesos: Organizaciones pueden priorizar:

- Operador pagos en crisis: Módulo 3 (Incidentes) $\uparrow$ 25%
- Asset manager con subcontratistas: Módulo 5 (Terceros) $\uparrow$ 20%
- Aseguradora TLPT-vulnerable: Módulo 4 (Vulnerabilidades) $\uparrow$ 20%

4.3 Análisis Estadístico Descriptivo

Por Módulo:

Estadísticos recomendados (si múltiples respondentes):

- Media: $(\sum \text{respuestas}) / N$
- Mediana: valor central (ordenado)
- Desv. Est.: $\sqrt{[(\sum (x - media)^2) / N]}$
- Rango: max - min
- Moda: respuesta más frecuente

Interpretación:

- Desv. Est. baja (<0.8) $\rightarrow$ consenso; respuestas homogéneas
- Desv. Est. alta (>1.2) $\rightarrow$ divergencia; perspectivas diferentes
 $\rightarrow$ Requiere facilitación para entender razones disonancia

Por Pregunta (Meta-Análisis):

Preguntas $>$ CMI_módulo:

- Identifican fortalezas específicas
- Ejemplo: Si 1.1.5 (Políticas responsabilidad) = 5, pero CMI_1 = 3.5
 $\rightarrow$ Governance definida; otras áreas rezagadas (p.ej., frequency reportes)

Preguntas $<$ CMI_módulo:

- Identifican gaps críticos
- Ejemplo: Si 5.3.3 (KPIs terceros) = 1, pero CMI_5 = 3.0
 $\rightarrow$ Terceros evaluados; monitoreo governance débil

4.4 Benchmarking (Comparativas)

Fuentes de datos externas para contexto:

19. CNMV Autoevaluación 2024:
20. 245 entidades respondieron
21. Publicó results: 32% full compliance, 40% partial, 28% low
22.
Benchmark: si tu CMI > 3.5, encima promedio sector

23.
KPMG Survey 2024:

24. EU financial sector
25. Módulo GAP analysis published
26.
Comparar: CMI_módulo vs. KPMG benchmark

27.
EBA Risk Assessment 2024:

28. Banking sector maturity indicators
29. Disponible: <https://www.eba.europa.eu/>

Benchmark: si tu CMI > 3.5, encima promedio sector

KPMG Survey 2024:

Comparar: CMI_módulo vs. KPMG benchmark

EBA Risk Assessment 2024:

Creación de dashboard benchmarking:

Módulo	Tu CMI	Benchmark EU	Status
Gobernanza	3.83	3.50	✓ Above
Riesgos	3.50	3.40	✓ Above
Incidentes	3.20	3.30	x Below
Vulnerabilidades	3.40	3.60	x Below
Terceros	2.80	3.10	x Below
IAM	3.90	3.80	✓ Above
Resiliencia	3.60	3.50	✓ Above
Capacitación	3.20	3.25	x Aligned
Compliance	3.40	3.60	x Below
TOTAL CMI	3.48	3.50	x -0.02

FASE IV: ANÁLISIS CUALITATIVO INTEGRADO

5.1 Análisis de Narrativa & Comentarios

Recopilación: Si encuesta incluye campos abiertos ("Commentarios"): capturar verbatim

Codificación temática:

Tema	Código	Ejemplos
Falta recursos	RES	"No budget para TLPT", "SIEM cost prohibitivo"
Falta expertise	EXP	"No tenemos red team", "CISO workload unsustainable"
Governance misalignment	GOV	"Board no entiende importancia", "Presupuesto anual no garantizado"
Terceros bloqueando	THIRD	"Cloud provider resiste audit rights", "Exit costs prohibitivos"
Regulatory ambiguity	REG	"DORA requirements not clear", "Autoridades enviando guidance conflictiva"
Technical debt	DEBT	"Legacy systems hard to patch", "Manual processes everywhere"
Competitive pressure	COMP	"Estamos atrás vs competencia", "Mercado espera innovation, no seguridad"

Frecuencia de códigos:

- Temas apareciendo 3+ veces = patrones emergentes
- Reporte: "Los comentarios convergen en 3 áreas críticas..."

5.2 Análisis de Divergencia Inter-Respondentes

Si múltiples respondentes:

Ejemplo: Pregunta 2.1.5 (FAIR framework)

- CISO responde: 2 (iniciativa incipiente)
- CRO responde: 3 (parcialmente implementado)
- Compliance responde: 1 (no implementado)

Divergencia: rango = 3-1 = 2 (alta; >1.5 = significant)

Interpretación: CISO y CRO ven algún progress; Compliance no lo conoce
→ Action: Asegurar comunicación cross-funcional sobre FAIR roadmap

Matriz de convergencia/divergencia:

Preguntas con Desv. Est. > 1.2:

- Revisión de gaps de comunicación cross-funcional
- Facilitación para alineamiento

Preguntas con Desv. Est. < 0.5:

- Consenso fuerte; control validado
- Comunicación cruzada aceptable

5.3 Correlación Entre Módulos (Análisis de Dependencia)

Hipótesis de relación:

Gobernanza → Riesgos → Incidentes

(Si gobierno débil, gestión riesgo sufre, respuesta lenta)

Riesgos → Terceros

(Si riesgos bien gestionados, due diligence terceros refine)

Vulnerabilidades → Capacitación

(Si mucho phishing exitoso, training no está funcionando)

Terceros → Resiliencia

(Si terceros críticos fallan, BD plans insuficientes)

Validación empírica:

Calcular correlación Pearson entre CMI_módulos:

Si $\text{Corr}(\text{CMI}_1, \text{CMI}_2) = 0.85$ (fuerte positiva)

→ Hipótesis validada; gobernanza impacta gestión riesgos

Si $\text{Corr}(\text{CMI}_3, \text{CMI}_8) = -0.05$ (sin relación)

→ Sorpresa; training no correlaciona con incidentes

→ Investigar: ¿training no relevante? ¿incidentes por otras causas?

FASE V: GENERACIÓN DE REPORTES EJECUTIVOS

6.1 Estructura de Reporte (3 Niveles)

NIVEL 1: Executive Summary (2 páginas)

[LOGO INSTITUCIÓN]

RESULTADOS ENCUESTA INTEGRAL DE CIBERSEGURIDAD DORA

Fecha: [Enero 2026]

Clasificación: Confidencial

RESUMEN EJECUTIVO

Posición Actual (CMI): 3.48 / 5.0
Benchmark Sector EU: 3.50 / 5.0
Status: x Levemente rezagado (-0.02)

HALLAZGOS CRÍTICOS:

1. Gestión Terceros (CMI 2.80): BRECHA CRÍTICA
 - Riesgo: Dependencia vendor no monitoreada
 - Acción inmediata: Audit terceros críticos Q1 2026
2. Vulnerabilidades (CMI 3.40): DEBAJO DE BENCHMARK
 - Riesgo: MTTD > 30 min; sin EPSS implementado
 - Acción inmediata: SIEM upgrade roadmap; EPSS feed integración
3. Incidentes (CMI 3.20): DEBAJO DE BENCHMARK
 - Riesgo: Notificación tiempos no DORA-compliant
 - Acción inmediata: Incident response drills Q1; automation deploy

FORTALEZAS:

- IAM (CMI 3.90): MFA widespread; segregation of duties strong
- Gobernanza (CMI 3.83): Board engaged; CISO reportería regular

RECOMENDACIÓN GLOBAL:

Posición sector-aligned pero gaps tácticas específicas requieren acción Q1 2026.
Presupuestación €1.2M; ROI: reducción riesgo incidente 45%; compliance DORA 85%-98%.

Próximos pasos: Board presentation Q1; detailed roadmap mapping (Fase VI).

NIVEL 2: Reporte Detallado (15-20 páginas)

Estructura:

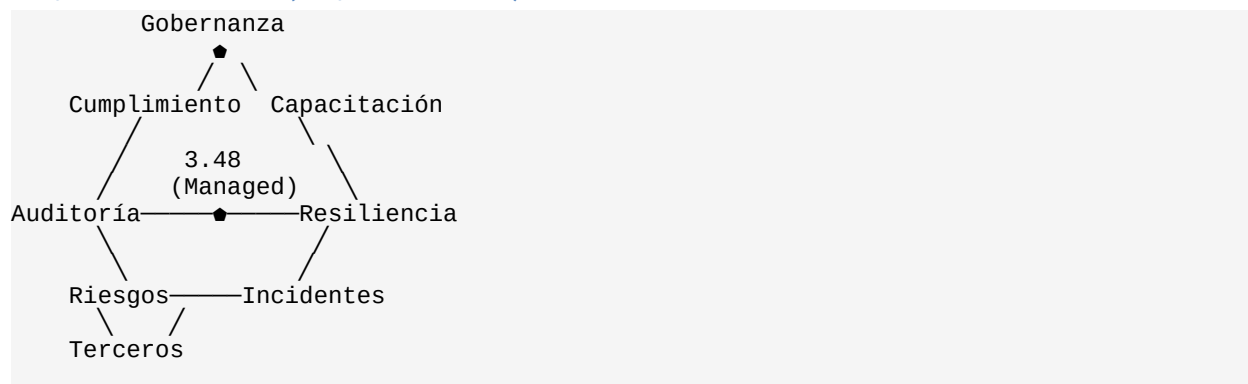
1. Portada + índice
2. Metodología (2 pág): Alcance, respondentes, limitaciones
3. Resultados CMI por módulo (8 pág): Gráficos + narrativa
4. Análisis modular profundo (6 pág): Hallazgos vs. benchmark; divergencias inter-respondentes
5. Riesgos identificados (2 pág): Priorización matriz riesgo (impacto vs. prob.)
6. Recomendaciones (3 pág): Acciones vs. timelines; dueños; presupuesto

NIVEL 3: Anexos Técnicos

- Encuesta completa + respuestas detalladas
- Datos estadísticos brutos
- Gráficos adicionales (scatter plots, heatmaps)
- Mapping DORA requirements vs CMI

6.2 Visualizaciones Recomendadas

Gráfico 1: Radar Chart (Perfil de Madurez)



Interpretación: Visualización general posición; identifica módulos altos/bajos a vista

Gráfico 2: Bar Chart (CMI por Módulo vs. Benchmark)

Gobernanza:	3.83	vs	3.50	✓
Riesgos:	3.50	vs	3.40	✓
Incidentes:	3.20	vs	3.30	✗
Vulnerabilidades	3.40	vs	3.60	✗
Terceros:	2.80	vs	3.10	✗ CRÍTICO
IAM:	3.90	vs	3.80	✓
Resiliencia:	3.60	vs	3.50	✓
Capacitación:	3.20	vs	3.25	✓
Compliance:	3.40	vs	3.60	✗

Gráfico 3: Heatmap de Riesgos (Priorización)

	IMPACTO ALTO	
	↑	
CRÍTICA	Terceros	Incidentes
MEDIA	Vuln.	Riesgos
BAJA	Capacit.	IAM
BAJA	← PROBABILIDAD → ALTA	

6.3 Comunicación de Resultados

Audiencias y formatos:

Audiencia	Formato	Contenido Clave	Tiempo
Junta/Board	Presentation 20 min	Executive summary; riesgos críticos; budget ask	Q1 meeting
C-Suite	Detailed report	Hallazgos modulares; recomendaciones; roadmap	Email distribution
CISO/Managers	Workshop 2h	Detalles técnicos; accionables por dueño; SLAs	Working session
Team técnico	Specifications	Detalles implementación; tickets; epics	Backlog planning

HERRAMIENTAS TÉCNICAS RECOMENDADAS

7.1 Platforms para Encuesta

Herramienta	Ventajas	Desventajas	Costo
Google Forms	Gratuita; integración Sheets; simple	Limited branching; UI básico	Free
SurveyMonkey	Análisis avanzado; reporting; conditional logic	UI cluttered; costoso escala	\$35-100/mo
Qualtrics	Enterprise-grade; AI analytics; XM platform	Muy caro; overfeature para PME	\$1K+ /mo
Typeform	UX limpia; mobile- friendly; conversational	Limited analysis; limited respondents free tier	\$35-100/mo

Recomendación: Google Forms para rápida; SurveyMonkey si análisis avanzado needed

7.2 Herramientas de Análisis

Excel/Google Sheets:

Fórmulas útiles:

- PROMEDIO(rango): media
- MEDIANA(rango): mediana (ord. data)
- DESVEST(rango): desv. est.
- CORREL(rango1, rango2): correlación
- Pivot tables: agregación por respondente/rol
- Conditional formatting: visualizar patterns

Software estadístico:

- **R (libre):** ggplot2, tidyverse para visualization avanzada
- **Python:** pandas, matplotlib, seaborn

- **SPSS**: usuario-amigable; GUI; costoso
- **Tableau**: BI platform; dashboards interactivos

7.3 Herramientas de Roadmapping

- Monday.com / Asana: Task management; SLAs; gantt charts
- Jira: Technical teams; agile sprints; impact tracking
- MS Project: Enterprise PM; resource allocation
- Lucidchart: Diagram DORA dependencies; swim lanes

INTERPRETACIÓN DE RESULTADOS

8.1 Matriz de Interpretación por CMI Range

CMI	Categoría	Interpretación	Urgencia
1.0-1.9	Ad-hoc	Riesgo crítico; respuesta reactiva; no framework formalizado	CRÍTICA - Acción inmediata
2.0-2.9	Developing	Iniciativas en curso; gaps significativos; roadmap needed	ALTA - Q1 2026
3.0-3.9	Managed	Baseline compliance; best practices parciales; mejora continua	MEDIA - Roadmap 2026
4.0-4.9	Integrated	Madurez avanzada; integración cross- funcional; leadership alignment	BAJA - Optimización
5.0	Optimized	Excelencia; continuous improvement; benchmarking industry	MÍNIMA - Maintain

8.2 Mapeo de Hallazgos a Riesgos DORA

Ejemplo: CMI_5 (Terceros) = 2.80 → Riesgos DORA

Deficiency Identificada:

- No monitoring continuo terceros
- Contratos sin cláusulas DORA
- No KPIs vendor compliance

Artículos DORA Afectados:

- Article 30: Gestión riesgos proveedores críticos
- Article 28: Due diligence precontractual
- Article 29: Monitoring postcontractual

Riesgos Materialization:

1. Vendor goes bankrupt sin notice → servicios críticos interrumpidos
2. Vendor sufre breach → datos cliente exfiltrados
3. Cloud provider degrada SLA → RTO incumplido
4. Subcontratista vendor violates compliance → cascada violations

Financial Impact (FAIR):

- LEF (Likelihood): 0.15 eventos/año (vendor incidents)
- LM (Loss Magnitude): €2.5M (breach + continuidad + regulatory fines)
- ALE: $0.15 \times €2.5M = €375K/año$ risk exposure

Recomendación: Invertir €150-200K en TPRM platform + governance → ROI 60-75% risk reduction

8.3 Validación de Resultados

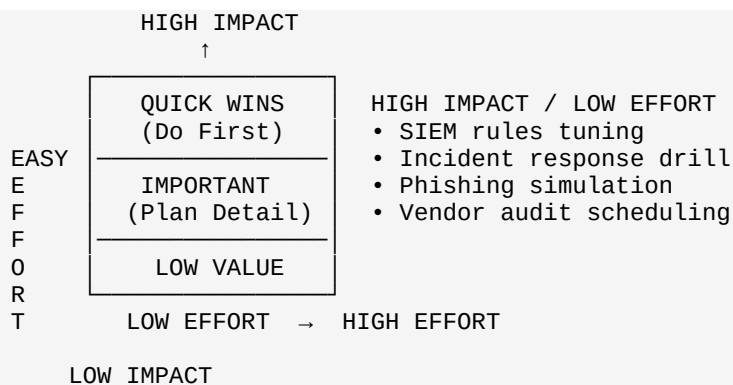
Sanity checks:

- ✓ CMI_módulo entre 1.0-5.0 (rango válido)
- ✓ CMI ponderado = promedio ponderado módulos (verificar cálculo)
- ✓ Preguntas específicas <CMI_módulo = areas para deep-dive
- ✓ Respondentes convergentes (Desv. Est. <0.8) = validación
- ✓ Respondentes divergentes (Desv. Est. >1.2) = investigar causas
- ✓ Correlaciones lógicas (Gobernanza-Riesgos) = valida; correlaciones nonsense = error

DERIVACIÓN DE ROADMAP DE MEJORA

9.1 Priorización de Iniciativas

Matriz de Priorización (Impact vs. Effort):



Ejemplo mappings:

Initiativa	Impact	Effort	Priority	Timeline	Budget
SIEM rules implementati on	HIGH	LOW	P1	Q1 2026	€50K
Vendor KPI dashboard	HIGH	MEDIUM	P1	Q1-Q2	€100K
TLPT red team exercise	HIGH	HIGH	P2	Q2-Q3	€150K
FAIR framework deployment	MEDIUM	MEDIUM	P2	Q2 2026	€80K
Board security training	MEDIUM	LOW	P1	Q1 2026	€5K
Data classification project	HIGH	HIGH	P3	H2 2026	€200K

9.2 Ownership y Accountability

Asignación de dueños:

P1 - SIEM Rules Implementation

- Owner: CISO
- Sponsor: CRO
- Timeline: Jan-Mar 2026
- Success Metric: MTTD < 30 min (vs. current 60 min)
- Quarterly Reviews: CRO governance meeting
- Budget: €50K (contractor support)

P1 - Vendor KPI Dashboard

- Owner: Vendor Risk Manager
- Sponsor: Chief Compliance Officer
- Timeline: Jan-Feb 2026
- Success Metric: 100% critical vendors monitored; alerts <24h
- Quarterly Reviews: Risk committee
- Budget: €100K (TPRM platform license + setup)

9.3 Roadmap Multi-Año

Visión 2026:

Q1 2026 (Jan-Mar): Foundation

- SIEM implementation + tuning
- Incident response drills (monthly)
- Vendor assessment completed
- Board training (Feb)

Q2 2026 (Apr-Jun): Acceleration

- TLPT red team exercise (begin)
- FAIR framework pilots (3 assets)
- Phishing simulation program launch
- Contracts renegotiation (80% critical)

Q3 2026 (Jul-Sep): Integration

- TLPT results & remediation tracking
- FAIR full deployment
- DR site failover testing
- Compliance audit readiness Q4

Q4 2026 (Oct-Dec): Optimization

- Annual reassessment (encuesta repeat)
- Lessons learned integration
- 2027 roadmap planning
- Supervisory submission readiness

Metrics de progreso (Quarterly dashboard):

Initiative	Q1	Q2	Q3	Q4	Target 2026
MTTD reduction	↓	↓↓	↓↓↓	↓↓↓	<30 min
Vendor monitoring	30%	60%	90%	100%	100%
TLPT completion	Plan	40%	90%	100%	Complete
FAIR models	0%	15%	50%	100%	100%
Contracts DORA-ified	20%	50%	80%	100%	100%
CMI improvement	3.48	3.65	3.85	3.98	>3.8

CONCLUSIÓN

Esta guía metodológica proporciona framework estructurado para administración, análisis e interpretación de encuesta DORA integral. Su aplicación rigurosa permite:

30. Diagnóstico honesto de posición cibernética actual
31. Benchmarking contra sector EU y mejores prácticas
32. Priorización basada en datos de iniciativas mejora
33. Roadmap ejecutable con ownership y timelines claros
34. Validación trimestral de progreso vs. targets

Éxito depende de:

- **Honestidad** en respuestas (no auto-report bias)
- **Multi-perspectiva** (CISO + CRO + Compliance convergent)
- **Facilitación** experta si divergencias
- **Governance** rigurosa en ejecución roadmap
- **Evolución continua** conforme threat landscape y DORA guidance evolucionan

Próximos pasos: Aplicar Phase VI (supervisory engagement) y establecer annual survey cadence para tracking madurez crecimiento.